Name : Yanish Bodas
Roll No : HH010426007
Course : FY BCA

DOMS | Page No.
Date / /

Case Study 2:

A university uses an operating system based examination management system to store records examination marks, faculty details, and question paper. The system has three main user group Students, Faculty and adminstrators. Student should be able to view only their own marks and download permitted learning materials. faculty member need to view student record and enter or modify marks. Administrators manage user accounts, permission and system configuration.

The university has assigned permission through roles but an audit review identifies the following events:

- At 10:00 the account student07 has three failed Login attempt
- At 10:03 Student07 ~~Sug~~ successfully logs in
- At 10:04 Student attempts to ~~open~~ Open ExamMarks.xlsx which contains marks for an entire class
- At 10:05, the system records an attempted modification of ExamMarks.xlsx and save the file successfully

At 10:15

At 10:20 an administrator discovers that a former faculty member's account is still active.

- The audit log is stored on the same server, and users with broad permission may able to modify or delete it.

DOMS | Page No.
Date / /

The university wants to protect confidentiality, integrity and availability

Questions:

Q1] Identify the main security ~~model~~ problems in the case study (4 marks)
List atleast four risks or weakness indicated by the scenario.

Q2] Explain the difference authentication and authorization using Student07 as an example (4M)
Distinguish identity verification from permission checking.

Q3] Recommend an access-control policy for students, faculty and administration. Justify your choices (5 marks).
Consider how permission should be assigned and managed.

Q4] Prepare a suitable access-control ~~policy~~ List (ACL) for ExamMarks.xlsx.
Specify appropriate read, write, and Delete permission for each user group.

Q5] Explain how the principal of least privilege should be applied in the system. (4 marks)
State what each group needs to do and which unnecessary permissions should be removed.

DOMS | Page No.
Date / /

Q6] Interpret the audit events from 9:00 to 10:05. What should the security team do next (5M)
Explain why the sequence is suspicious without assuming that it proves an attack.

Q7 Identify atleast five events that should be recorded in audit logs.
Include login, file, account, permission and/or administrative events

Q8] Explain why the audit logs must be protected and recommend two ways to protect them.

Q9] What action should be taken regarding the former faculty member's active account
Explain
Relate your answer to account management and access ~~con~~ removal.

10) Suggest a practical way/incident response and corrective action plan for the university. Include investigation, access review, policy change and follow up monitoring

DOMS | Page No.
Date / /

Case Study Answers

1A] • The main security problem is poor audit log and lack of Access Control Mechanism

B] • Four risk are:
a) Broken Access Control
b) Insecure Audit log
c) Active former Employee Account
d) Inadequate lockout policy

2]

A]	Authentication	Authorisation
•	Proving who you are, & Verifies who you are	Verifies what you are allowed to do
•	Checks the identity of a user.	Checks the user's permission.
•	Eg: At 10:00 Student07 fails authentication three times.	Eg: At 10:04, now that Student 07 is authenticated he tries to open ExamMarks.xlx

B] 2]	Identity Verification	Permission Checking
i)	The core question "Are you really who you say you are."	The core question "Are you allowed to touch this file".
ii)	It confirms the user's identity	It checks the user's access rights.

DOMS | Page No.
Date / /

3]

1] Student:- Restricted access to Read-Only for their own personal grades and assignment learning materials.

2] Faculty :- Grant Read & Write access exclusively to the exam files for the classes they teach.

3] Administerators :- Grant full control over system configuration, accounts, provising & user permissions

4] Access Control List (ACL) for examMarks.xlsx.

1] Students : Deny all permission except of viewing their own marks (Read Only).

2] Faculty : Allow Read and Write permission but deny deleting.

3] Administrator : Grant all the permission

5] The principle of least privilege means that every user should receive only the minimum permissions required to perform their job.

(i) Students - should only be allowed to view their own marks.

(ii) Faculty : Can read/write marks only of their class or course

(iii) Administrator : Manage account and configuration

6] Interpreting the audit events from 10:00-10:05

10:00 : Three failed login attempt. This can be forgotten password or password guessing

10:03 : Successful login by either real student or someone who guessed the password.

10:04 and 10:05 : attempts to open and modify a file outside student's role.

The sequence is suspicious because of the multiple login failed attempt and due to accessing a file other than the role.

7] The events that should be recorded in the audit ~~are~~ logs are:

- Failed Login Attempts
- Successful Login
- Unauthorised File Access Attempt
- Account permission Changes
- Administrative Activity.

DOMS | Page No.
Date / /

8] Audit logs help identify suspicious activities and find out who is responsible. If they are changed or deleted, investigations become difficult.

1] Allow only authorised people to access the logs

2] Store logs on a separate secure server with backups.

9] The university should immidiately disable the former faculty member's account and remove all access permission. It should also remove the account from faculty groups and end any active sessions. The audit logs should be checked for suspicious activities. This will prevent unauthorized access to student records and examination marks.

10] The university should follow these steps to improve system security

1] Investigation: Examine audit logs to investigate the failed login attempts, successful login, and unauthorized file access by Student07.

2] Access Review: Review all user accounts and permission to ensure that user can access only the files they need.

3) Policy Changes: Enforcing strong passwords, multifactor authentication, and account lockout after repeated failed login attempts

4) Follow up Monitoring: Regular check audit logs and conduct security audits to prevent similar problems in future.